玄武合规引擎

自主 AI 驱动的安全合规检测平台

商业计划书 · 市场分析 · 技术架构

Xuanwu Compliance Engine — Powered by the Odysseus Engine

文件信息

版本：	1.0
日期：	2026年4月
密级：	机密
适用范围：	天使投资人（须签署保密协议）
编制方：	DeepGuard 产品团队

1. 执行摘要

玄武合规引擎是一款全自主、AI 驱动的企业级安全合规平台，能够同时扫描源代码仓库与云基础设施配置，对照多项安全治理政策框架进行深度比对分析，最终生成专业级审计 PDF 报告并附带修复建议。

时代背景：Mythos 模型的警示

2026年4月，Anthropic 公开披露其 Claude Mythos 模型的能力：该模型能够**自主发现并利用软件漏洞**，规模与深度远超任何先前工具——无论人工还是自动化手段。Mythos
在所有主流操作系统和浏览器中发现了数千个零日漏洞，其中最老的已有 27 年历史。超过 99%
的漏洞在披露时仍未修补。

Anthropic 因网络安全担忧拒绝公开发布 Mythos，并启动了 Project Glasswing——一个联合
Amazon、Apple、Google、Microsoft 等十二家科技巨头、承诺投入 1 亿美元的防御性修复联盟。

这是继 Log4Shell 以来企业安全格局最深刻的转变——但 Glasswing 的扫描范围仅限于开源基础设施，不涵盖：

- 企业专有应用代码
- 云基础设施配置
- AI 大模型集成应用

这正是玄武合规引擎所填补的空白。

核心价值主张

- **数据主权保障**：全私有化部署，代码永不离开企业安全边界
- **源代码 + 云配置一体化扫描**：单一报告覆盖三个合规层次
- **AI 深度推理**：基于大模型推理而非规则匹配，发现传统工具无法检测的漏洞
- **国产大模型支持**：原生支持通义千问 Qwen3-Coder、DeepSeek-R1，满足信创与数据主权要求
- **覆盖中国核心法规**：等保 2.0、《网络安全法》、《数据安全法》、《个人信息保护法》、《生成式 AI 管理办法》
- **多云支持**：AWS、阿里云、腾讯云、华为云、Azure、GCP，以及离线私有数据中心

投资摘要

所有金额以新加坡元（SGD）计，参考汇率 1 SGD ≈ 5.3 人民币（CNY）。

指标	数据
天使轮融资需求	SGD 160 万（约人民币 848 万）
18 个月 ARR 目标	SGD 340 万（约人民币 1,802 万）
5 年 ARR 目标	SGD 2,738 万（约人民币 1.45 亿）
预计退出估值	SGD 2.7 亿—4 亿（约人民币 14 – 21 亿）
战略退出方向	奇安信、华为、腾讯安全、深信服、CrowdStrike、Wiz 战略收购；或港交所/科创板上市
可服务市场（SAM）	约 80 亿—100 亿美元（2027年），含亚太区高速增长

2. 神话溯源：玄武引擎命名哲学

2.1 玄武：深海之守护神

玄武是中国传统神话中的北方守护神，四象之一，黑色龟蛇合体，象征北方、水、冬季与无上防护之力。

- 玄（xuán）：深邃、神秘、幽暗、渊博——对应"Deep"（深度扫描）
- 武（wǔ）：武力、守护、战将——对应"Guard"（守卫防护）

玄武因此成为"DeepGuard"在中文神话体系中最精确的映射：一位深藏玄机、以守护为本的神祇。

据道教典籍记载，玄武本为凡人，奉天命修炼于武当山。神明告知他：欲得真正洁净，须将吸纳世间污浊的肠胃舍弃。他将五脏投入海中，化为龟蛇二灵，自身则升华为北方玄武大帝。

这一神话与企业合规的现实高度契合：企业必须舍弃被历史漏洞污染的旧有工具（陈旧的规则扫描器、人工审计流程），以玄武引擎的 AI 深度推理取而代之，方能实现真正的安全洁净。

2.2 Mythos 披露：神话与现实的交汇

Anthropic 将其最强大的模型命名为
Mythos——希腊语中"神话/故事"之意，即那些揭示世界隐藏真相的原始叙事。

这一命名绝非偶然：Mythos 模型所发现的漏洞，并非全新的危险，而是原始的、自软件诞生之初便已植入其中的弱点——沉睡数十年，只待足够强大的智慧将其唤醒。

中国神话中亦有同样的警示智慧：

- 比干的七窍玲珑心——他看透了纣王朝廷的腐败，因直言而死；他的发现不可忽视，正如云配置扫描器 Cassandra（比干）报告的安全隐患不可无视
- 封神演义中的姜子牙——他不以武力，而以谋略（智谋）调遣诸神，逐一化解商朝的重重威胁，正如玄武引擎协调各专项 Agent 完成合规分析
- 钟馗驱鬼——他专职揭露以正常面目潜伏的鬼魅，正如 IaC 分析器在合法配置文件中检测到隐藏威胁

2.3 玄武引擎的九天神将

玄武引擎（LangGraph 多智能体编排核心）统领一支以神话人物命名的专项 Agent 团队：

神将	角色	神话渊源
姜子牙	编排核心	《封神演义》战略总师；以智谋而非武力统御全局
太白金星	数据摄取网关	天界信使；上天入地、穿越所有边界传递信息
伏羲	政策解析器	八卦创制者；将宇宙间所有模式编码为基础法则
千里眼	代码索引器	千里眼神将；能看穿万里之外的一切，无一遗漏
钟馗	IaC 分析器	驱魔天师；专门揭露伪装成合法存在的隐匿邪魅
比干	云配置检测器	七窍玲珑心；以无上智慧洞察欺骗，因直言而牺牲

神将	角色	神话渊源
观音菩萨	合规映射引擎	智慧与慈悲菩萨；公正裁断，赋予推理而非规则
神农氏	修复建议器	尝百草之神农；系统性地将危险转化为精准疗方
织女	报告组装器	天上织女；以无比精准与耐心编织宇宙锦缎
东海龙王	密钥管理层	东海龙王；在龙宫深处守护无数宝物，固若金汤
风伯	任务队列与工作流	风神；掌管风向与流速，调配旅途方向与节奏
门神	身份认证层	秦琼、尉迟恭；守护殿门，验明正身，拒绝非授权者

3. 问题陈述：企业合规的三重危机

3.1 中国合规监管的急剧收紧

中国及大中华区企业面临前所未有的合规压力，多部重量级法规相继生效并同步执行：

《网络安全法》（2017年）：强制要求关键信息基础设施运营者进行等保评估，违规最高罚款 100 万元并吊销营业执照。

《数据安全法》（2021年）：建立数据分类分级制度，重要数据处理须经安全评估，违规最高罚款 1,000 万元。

《个人信息保护法》（2021年）：类似欧盟 GDPR，对个人信息处理活动施加严格限制，违规最高罚款 5,000 万元或上年营业额 5%。

网络安全等级保护 2.0（等保 2.0）：GB/T 22239-2019
强制要求二级及以上系统每年开展等保测评，覆盖技术要求与管理要求共计数百条控制项。

《生成式人工智能服务管理暂行办法》（2023年）：国内首部专门针对生成式 AI 的监管规定，要求安全评估、内容过滤、数据标注规范，以及可追溯的风险管理体系。

现实困境：上述合规工作当前完全依赖人工审计，每次等保三级评估耗时 3 – 6 个月，费用 50 – 200 万元，且结论难以持续更新。没有任何现有工具能够将代码扫描与云配置检查一体化，并以 AI 推理取代规则匹配。

3.2 数据主权的绝对红线

中国法规对数据出境有严格限制：《数据安全法》第 31 条、《个人信息保护法》第 38 条均规定，重要数据和个人信息在出境前须经国家网信办安全评估。

这意味着：企业代码与云配置数据绝对不能发送至境外 AI API（包括 Anthropic、OpenAI、Google）进行分析。
玄武合规引擎的私有化部署模式（阿里云 VPC / 腾讯云 VPC / 华为云 VPC / 企业自有数据中心）是唯一合法且合规的解决路径：代码永不离开企业安全边界。

3.3 AI 漏洞发现能力的跃级威胁

Mythos 模型的披露证明了一个令人震惊的现实：每一个企业代码库，都几乎确定含有传统扫描工具从未发现、也永远无法发现的深层漏洞。

对中国企业而言，这一威胁尤为紧迫：

- 众多国内企业的核心业务系统建立于 10 – 20 年前的技术栈之上
- 等保 2.0 的检测能力基于规则库，无法检测 AI 可发现的新型深层漏洞类别
- 国家级威胁行为者（APT 组织）具有最强动机在 Mythos 类工具公开之前率先利用这些漏洞

3.4 现有工具的根本局限

工具类型	代表产品	核心局限
国内等保合规工具	天融信、绿盟、安恒	规则检测，无 AI 推理；不扫描源代码；不支持 AI 治理框架
国内 SAST 工具	奇安信代码卫士、默安科技	代码扫描，但无云配置关联；无自定义策略；无 AI 治理
国际 SAST 工具	Snyk、Checkmarx、Veracode	数据主权问题；不支持国产云；不支持中国法规框架
云原生安全工具	阿里云云安全中心、腾讯云安全	单云范围；不扫描源代码；无 LLM 推理；无自定义策略

4. 解决方案：玄武合规引擎

玄武合规引擎概述

一套全自主 AI 代理系统，接受以下任意组合输入：

- 源代码仓库（GitHub、GitLab、Gitee、Bitbucket 或 ZIP 上传）
- 云基础设施配置（IaC：Terraform、CloudFormation、CDK；国内：阿里云 ROS、华为云 CFW）
- 实时云环境连接（只读 API 扫描运行中的配置）
- 安全政策文档（预设框架或自定义上传）

输出一份专业合规报告，包含：

- 代码层、IaC 层、云配置层三层统一合规发现
- 每项控制要求的通过/失败/部分通过状态及精确证据引用
- 按漏洞可利用性排序的修复手册（代码补丁 + IaC 修复 + CLI 命令）
- 管理层摘要：总体合规得分与风险评级
- 适用于外部审计机构和监管机构的审计证据报告

4.1 部署模式

模式	描述	适用场景
SaaS（托管云）	DeepGuard 多租户托管	中小企业、初创公司
私有云 — AWS	部署于客户 AWS VPC	合规要求较高的跨国企业
私有云 — 阿里云	部署于客户阿里云 VPC	国内企业、金融机构

模式	描述	适用场景
私有云 — 腾讯云	部署于客户腾讯云 VPC	互联网企业、游戏公司
私有云 — 华为云	部署于客户华为云 VPC	政务、央企、军工配套
离线 / 私有数据中心	Kubernetes + 开源大模型	国防、涉密、信创环境

4.2 扫描层次

第一层 — 应用代码：源代码仓库、依赖库、API、认证流程、数据处理逻辑、大模型集成模式

第二层 — 基础设施即代码（IaC）：Terraform、CloudFormation、阿里云 ROS、华为云模板——部署前政策合规检查

第三层 — 实时云配置：通过只读 API 扫描运行中的云资源——IAM 策略、网络拓扑、存储配置、加密设置、日志审计状态

4.3 三大国内云专属部署架构

玄武合规引擎为阿里云、腾讯云、华为云分别提供经过优化的原生部署架构，每套架构均使用该云厂商的原生托管服务，确保最佳性能、合规性与成本效益。

阿里云部署架构（推荐首选）

适用场景：国内互联网企业、金融科技公司、电商平台、新零售、跨境电商

图1：玄武合规引擎 — 系统架构总览（姜子牙编排引擎 · 九天神将代理图）

IaC 支持：阿里云 ROS（资源编排服务）模板 + Terraform `alicloud` Provider

LLM 选项：

- 阿里云百炼 Qwen3-Coder-Plus（VPC 端点，推荐）
- 自托管 Qwen3-Coder-Next-80B 于 ACK GPU 节点（极致数据主权）

等保适配：与云上等保 2.0 三级最佳实践深度对齐，可直接输出阿里云等保合规评估报告

腾讯云部署架构

适用场景：互联网公司、游戏企业、视频平台、社交电商、微信生态企业

图1：玄武合规引擎 — 系统架构总览（姜子牙编排引擎 · 九天神将代理图）

IaC 支持：Terraform `tencentcloud` Provider + 腾讯云资源编排 TIC

LLM 选项：

- 腾讯云混元大模型（专线接入，推荐）
- 腾讯云托管 DeepSeek-R1（企业专属部署）
- 自托管 Qwen3-Coder-Next-80B 于 TKE GPU 节点

特色优势：与微信企业微信生态深度集成；腾讯云市场上架后可触达腾讯生态内数百万企业客户

华为云部署架构（政务 / 央企 / 信创首选）

适用场景：政府机关、央企、国有银行、军工配套企业、电信运营商、信创环境

图1：玄武合规引擎 — 系统架构总览（姜子牙编排引擎 · 九天神将代理图）

IaC 支持：Terraform `huaweicloud` Provider + 华为云资源编排 RFS

LLM 选项：

- 华为云盘古大模型（内网接入，推荐）
- 华为云托管 DeepSeek-R1（企业专属部署）
- 自托管 Qwen3-Coder-480B 于 CCE GPU 节点（Atlas 800 推理卡）
- 国密算法支持：SM2/SM3/SM4 全链路加密（信创等保强制要求）

信创专项：

- 支持麒麟操作系统（KylinOS）、统信 UOS 容器节点
- 华为 Atlas 推理加速卡（NPU）原生支持 LLM 推理
- 可申请华为云信创合规认证，进入信创软件目录

三云部署对比

能力	阿里云	腾讯云	华为云
容器服务	ACK（EKS 级别）	TKE（成熟稳定）	CCE（政务认证）
数据库	PolarDB（pgvector）	TDSQL-C（pgvector）	GaussDB（国产，pgvector）
对象存储	OSS	COS	OBS
密钥管理	KMS	KMS	DEW（支持国密）

能力	阿里云	腾讯云	华为云
任务队列	MNS	TDMQ（Pulsar）	DMS Kafka
自有大模型	通义千问 Qwen	混元 Hunyuan	盘古 PanGu
DeepSeek 托管	支持	支持	支持
国密算法	部分	部分	全面支持
信创认证	部分	部分	深度适配
政务合规	良好	良好	最优
互联网生态	最优	最优	一般
IaC Provider	alicloud（成熟）	tencentcloud（成熟）	huaweicloud（完善）
市场覆盖	全行业领先	互联网/游戏领先	政务/央企领先

5. 市场机会

5.1 中国网络安全市场

中国网络安全产业规模（工信部/中国信通院数据）：

指标	数据
2023 年市场规模	约人民币 663 亿元（约 93 亿美元）
2027 年预测规模	约人民币 1,500 亿元（约 208 亿美元），CAGR 22.7%
等保测评市场	约人民币 50 – 80 亿元/年，以每年超 20% 速度增长
AI 安全细分市场	2024 年起进入爆发式增长，预计 2026 – 2028 年翻三番

来源：中国信通院《中国网络安全产业白皮书（2024年）》；工业和信息化部网络安全产业统计

5.2 亚太及全球市场

细分市场	2024 年规模	2030 年预测	CAGR
应用安全测试（AST）	91.9 亿美元	284 亿美元	17.5%
云安全态势管理（CSPM）	42 亿美元	146 亿美元	28.3%
治理风险合规（GRC）软件	476 亿美元	1,051 亿美元	11.9%
AI 治理工具	18 亿美元	139 亿美元	40.2%
DevSecOps	61 亿美元	459 亿美元	28.4%

5.3 Mythos 带来的需求激增

Mythos 披露事件对市场需求产生离散式冲击效应，类比历史事件的市场反应：

- Log4Shell（2021年12月）：事件后当季企业安全软件支出增长 34%，漏洞管理和 SAST 工具需求最为突出
- SolarWinds（2020年）：触发多年供应链安全和代码完整性支出增加

Mythos 的质变在于：它不是单一漏洞，而是结构性能力的揭示——证明了每个企业代码库中都存在传统工具从未发现的整类漏洞。云安全联盟（CSA）将其描述为"每月触发多个 Log4j 级事件"。

5.4 中国监管红利

中国的监管环境正在为 AI 驱动的合规工具创造确定性的非自由裁量支出：

- 等保 2.0
  强制测评：二级及以上系统（覆盖几乎所有上市公司和大型企业）每年强制测评，创造稳定的合规工具需求
- 《生成式 AI 管理办法》安全评估要求：2023年起所有境内 AI 服务须完成安全评估，尚无高质量自动化工具
- 央企数字化转型：国务院国资委推动央企"数字化转型"，配套安全合规投入有法规依据
- 信创市场：党政机关、关键基础设施强制推广国产软硬件，国产合规工具具有天然政策优势

---

6. 竞争格局与差异化优势

6.1 国内竞争对手分析

竞争对手	核心能力	局限
奇安信（代码卫士）	国内领先 SAST，代码扫描	规则匹配，无 LLM 推理；无云配置关联；无 AI 治理框架
绿盟科技	等保合规咨询 + 扫描工具	无源代码扫描；无 LLM；无跨云统一报告
深信服科技	EDR、VPN、云安全	不扫描应用代码；无 AI 治理；无自定义策略
安恒信息	等保测评工具	规则检测；无 AI 推理；报告格式不适用外部审计
默安科技	DevSecOps 代码安全	早期阶段；无云配置关联；无 AI 治理

核心差距：所有国内竞争对手均未将源代码扫描、云配置扫描与 LLM 深度推理三者整合为单一平台，且无一支持 AI 治理框架（生成式 AI 管理办法、ISO 42001）的自动化检测。

6.2 差异化能力矩阵

能力	国内头部工具	国际 SAST	云原生安全	**玄武合规引擎**
源代码扫描	部分	是	否	是
IaC 扫描	否	部分	部分	是
实时云配置扫描	单云	否	单云	AWS+阿里+腾讯+华为
LLM 深度推理	否	否	否	是
自定义策略文档摄入	否	否	否	是
等保 2.0 全自动映射	部分	否	否	是
AI 治理框架支持	否	否	否	是
审计级 PDF 报告	基础	基础	否	是
私有化 / 离线部署	部分	否	否	是
国产大模型支持	否	否	否	是（Qwen / DeepSeek）
代码不出境保障	部分	否	否	架构级保障

6.3 信创市场的战略护城河

玄武合规引擎天然具备参与信创（IT应用创新）市场的条件：

- **国产大模型优先**：原生支持通义千问 Qwen3-Coder、DeepSeek-R1，可以完全不依赖境外 API
- **可申请信创目录**：符合信息技术应用创新工作委员会对安全软件的认定条件
- **国产云原生部署**：阿里云 ACK、腾讯云 TKE、华为云 CCE 原生支持

---

7. 商业模式与定价

所有价格以新加坡元（SGD）计，括号内为参考人民币（CNY）价格，汇率 1 SGD ≈ 5.3 CNY。

7.1 SaaS（托管云）

方案	月费（SGD）	月费参考（CNY）	内容
初创版	SGD 680	约 ¥3,604	5 个仓库，OWASP Top 10，3 用户，10 份报告/月
专业版	SGD 3,000	约 ¥15,900	25 个仓库，全标准框架，15 用户，CI/CD 集成，1 个云账户
企业版	SGD 8,800	约 ¥46,640	100 个仓库，自定义策略，50 用户，3 个云账户，API 接入
旗舰企业版	SGD 20,000	约 ¥106,000	无限仓库，独立租户，无限云账户，定制 SLA，SSO/SAML

7.2 私有化部署（VPC 专属部署）

方案	年费（SGD）	年费参考（CNY）	内容
私有云标准版	SGD 115,000	约 ¥609,500	单云，50 仓库/月，3 个框架，20 用户
私有云专业版	SGD 200,000	约 ¥1,060,000	单云，无限仓库，全框架含 AI 治理，100 用户
多云专业版	SGD 300,000	约 ¥1,590,000	最多 3 个云，无限用户，含 CI/CD SDK
离线 / 信创版	SGD 380,000	约 ¥2,014,000	自托管国产大模型，Kubernetes 离线，全框架，无限用户
专业服务	SGD 2,000/天	约 ¥10,600/天	部署、框架定制、云连接器配置、等保材料协助

7.3 渠道合作

中国市场强依赖渠道。玄武合规引擎与以下渠道类型合作：

渠道类型	返利模式
大型系统集成商（中科软、软通动力、赛迪等）	合同额 25% 渠道折扣
云厂商 ISV 合作（阿里云市场、腾讯云市场）	20% 渠道分成
等保测评机构合作（全国 200+ 授权机构）	按项目分成，合作测评包
安全厂商联合销售（绿盟、安恒等）	联合方案，利润分享

---

8. 市场进入策略

8.1 战略定位

玄武合规引擎定位为"后 Mythos 时代，大中华区首选主权 AI 合规平台"——唯一能将 Mythos 级 AI 推理能力应用于企业专有代码和云环境、完全在企业安全边界内运行、支持国产大模型、覆盖中国核心法规的平台。

8.2 第一阶段：新加坡基点（第 1–6 个月）

为何新加坡先行：

- 新加坡是中资企业在东南亚的区域总部集中地（超过 4,000 家中资企业在新注册）
- MAS TRM 为金融机构创造强制合规需求
- 新加坡 - 中国数字经济合作协议为跨境业务提供背书
- 新加坡作为中立司法管辖区，可同时服务西方客户和中国客户

行动：

- 90 天付费试点，完成即签正式合同，须有案例权利
- 重点：MAS TRM + OWASP ASVS L2 + AWS/阿里云基础设施扫描
- 申请新加坡企业发展资助（EDG）和 MAS FSTI 资助（最高 SGD 100 万）

KPI： 5 个付费设计合作伙伴；月 ARR 达 SGD 40 万；3 份被外部审计机构接受的合规报告

8.3 第二阶段：大中华区扩张（第 6–18 个月）

香港（第 6–12 个月）：

- 香港金管局操作风险管理指引（ORMS）要求
- 证监会科技风险管理指引
- 2024 年生效的《网络安全条例》强制等级评估
- 通过香港 FinTech 认证，进入香港金融科技生态

台湾（第 12–18 个月）：

- 金管会资安强化要求
- 国家通讯传播委员会（NCC）资安规范
- 美国《芯片和科学法案》带来的供应链合规需求

中国大陆（第 12 个月起，通过合作伙伴模式）：

- 与国内等保测评机构（ISC 授权机构）签订合作协议
- 与安全厂商（绿盟科技、安恒信息）开展联合方案

- 申请信创软件目录认定
- 设立中国境内实体（上海或北京）以满足数据本地化要求
- 目标客户：已在新加坡设立区域总部的中国科技公司（字节跳动、TikTok、阿里巴巴国际站、腾讯国际）

KPI（第 18 个月）： ARR 达 SGD 340 万；香港 3 家金融机构客户；中国大陆 2 家合作伙伴协议；阿里云市场上架

8.4 销售动作

客户类型	主要决策人	销售方式	销售周期	合同金额（SGD）
中小企业 SaaS	CTO / 技术负责人	自助试用	2 – 4 周	SGD 8千 – 3.5万
中型企业私有化	CISO + 安全总监	直销 + POC	4 – 8 周	SGD 3.5万 – 11.5万
大型企业多云版	CISO + CTO + 采购	企业销售 + 专业服务	3 – 6 个月	SGD 20万 – 38万
政府 / 央企	信息安全处 / 科技部门	招标 / 合作伙伴渠道	6 – 12 个月	SGD 27万 – 67.5万
等保测评合作	测评机构负责人	渠道合作	1 – 3 个月	项目分成

9. 财务预测

所有数字以新加坡元（SGD）计，括号内为参考人民币。汇率：1 SGD ≈ 5.3 CNY。

9.1 营收预测（保守口径）

年份	企业私有化部署	企业 SaaS	渠道合作	**总 ARR (SGD) **	**总 ARR（参考 CNY）**	新增客户	毛利率
第 1 年	SGD 57万（3 客户）	SGD 24.3万（6 客户）	SGD 0	SGD 81.3万	约 ¥431 万	9	74%
第 2 年	SGD 208万（8 客户）	SGD 72.9 万（18 客户）	SGD 24.3万	SGD 305万	约 ¥1,617 万	+21	79%
第 3 年	SGD 567 万（18 客户）	SGD 170 万（35 客户）	SGD 97.2万	SGD 834万	约 ¥4,420 万	+44	83%
第 4 年	SGD 1,134万（35 客户）	SGD 324 万（60 客户）	SGD 203万	SGD 1,661万	约 ¥8,803 万	+67	85%
第 5 年	SGD 1,782万（55 客户）	SGD 567 万（100 客户）	SGD 389万	SGD 2,738万	约 ¥1.45 亿	+80	87%

注：以上预测未计入 2026 年 7 月 Glasswing 披露报告带来的需求激增效应，实际表现预计超过保守口径。

9.2 成本结构

薪资基准：新加坡 2025/2026 市场薪资，含雇主 CPF（17%）及标准福利。

成本类别	人数	第 1 年（SGD）	第 2 年（SGD）	第 3 年（SGD）
技术团队	4→8→12 人			
CTO + 首席工程师	2 人	SGD 59万	SGD 59万	SGD 59万
高级工程师	2→4→5 人	SGD 38万	SGD 76万	SGD 95万
中级工程师	0→2→4 人	SGD 0	SGD 27.4万	SGD 54.8万
技术小计		*SGD 97万*	*SGD 162.4万*	*SGD 217.5万*
销售与市场	1→4→6 人			
销售总监	0→1→1 人	SGD 0	SGD 25.7万	SGD 25.7万
企业客户经理	1→2→3 人	SGD 18.5万	SGD 37万	SGD 55.5万
市场经理	0→1→2 人	SGD 0	SGD 11.5万	SGD 23万
销售市场小计		*SGD 18.5万*	*SGD 74.2万*	*SGD 104.2万*
云基础设施（SaaS 平台）	—	SGD 6.5万	SGD 13万	SGD 24.5万
G&A + 法律合规	—	SGD 18万	SGD 24万	SGD 31万
总运营支出		SGD 140万	SGD 294.3万	SGD 408.3万

9.3 融资需求

天使轮：SGD 160 万（约人民币 848 万）

- 用途：18 个月核心团队运营（CTO + 2 位高级工程师 + CEO/商务）；MVP 产品；5 个设计伙伴合同
- 可申请新加坡政府资助延长跑道：MAS FSTI（最高 SGD 100 万）；企业发展资助 EDG（最高覆盖 70% 合格成本）

A 轮：SGD 800–1,100 万（预期第 18 个月触发，届时 ARR 超 SGD 200 万）

- 用途：扩充销售团队；大中华区市场进入；多云连接器开发；SOC 2 Type II 认证；信创认定申请

盈亏平衡： 预计第 24 个月，基于 A 轮第 18 个月到账

---

10. 风险评估

风险	可能性	影响	缓解措施
LLM 产生误报影响审计可信度	中	高	Semgrep/AST 验证层；每项发现须引用具体代码证据；人工复审门控；持续基准测试
奇安信等国内头部厂商快速跟进 AI 功能	中	高	奇安信无多云代码 + 配置统一架构；技术追赶需 18 – 24 个月；先发优势 + AI 治理独家覆盖
中国监管政策变化影响产品定义	中	中	保持与工信部、网信办标准跟踪；聘请国内法律合规顾问；产品框架模块化，可快速迭代

风险	可能性	影响	缓解措施
数据主权要求升级影响 SaaS 模式	低	中	私有化部署模式本质上免疫此风险；SaaS 客户已有境外数据处理豁免机制
国产大模型质量不足影响离线模式	低	中	Qwen3-Coder-Next-80B SWE-Bench 超 70%，超越 GPT-4o；DeepSeek-R1 671B 性能对标前沿模型
地缘政治风险影响大中华区业务	中	中	新加坡作为中立司法管辖区具有天然缓冲；产品架构不依赖任何境外 API
关键漏洞漏检的法律责任	中	高	合同免责声明（辅助专业人工审核，非替代）；职业责任险；参照 Checkmarx/Veracode 行业先例

11. 技术架构：玄武引擎与九天神将

11.1 架构哲学：数据主权优先，多云原生

玄武合规引擎从设计之初即以数据主权为第一原则：

- **每一处云基础设施边界均设抽象层**：存储、计算、密钥、队列、LLM 均通过云中立接口与可插拔适配器访问
- **Kubernetes 优先运行时**：代理执行层运行于标准 Kubernetes，支持阿里云 ACK、腾讯云 TKE、华为云 CCE、OpenShift 或裸机 K8s
- **开放标准持久化**：PostgreSQL（pgvector）用于向量存储和状态；S3 兼容对象存储（阿里云 OSS、腾讯云 COS、华为云 OBS、MinIO 离线）；标准 OIDC 认证

11.2 系统架构总览

图1：玄武合规引擎 — 系统架构总览（姜子牙编排引擎 · 九天神将代理图）

11.3 代理流水线——九天神将作战序列

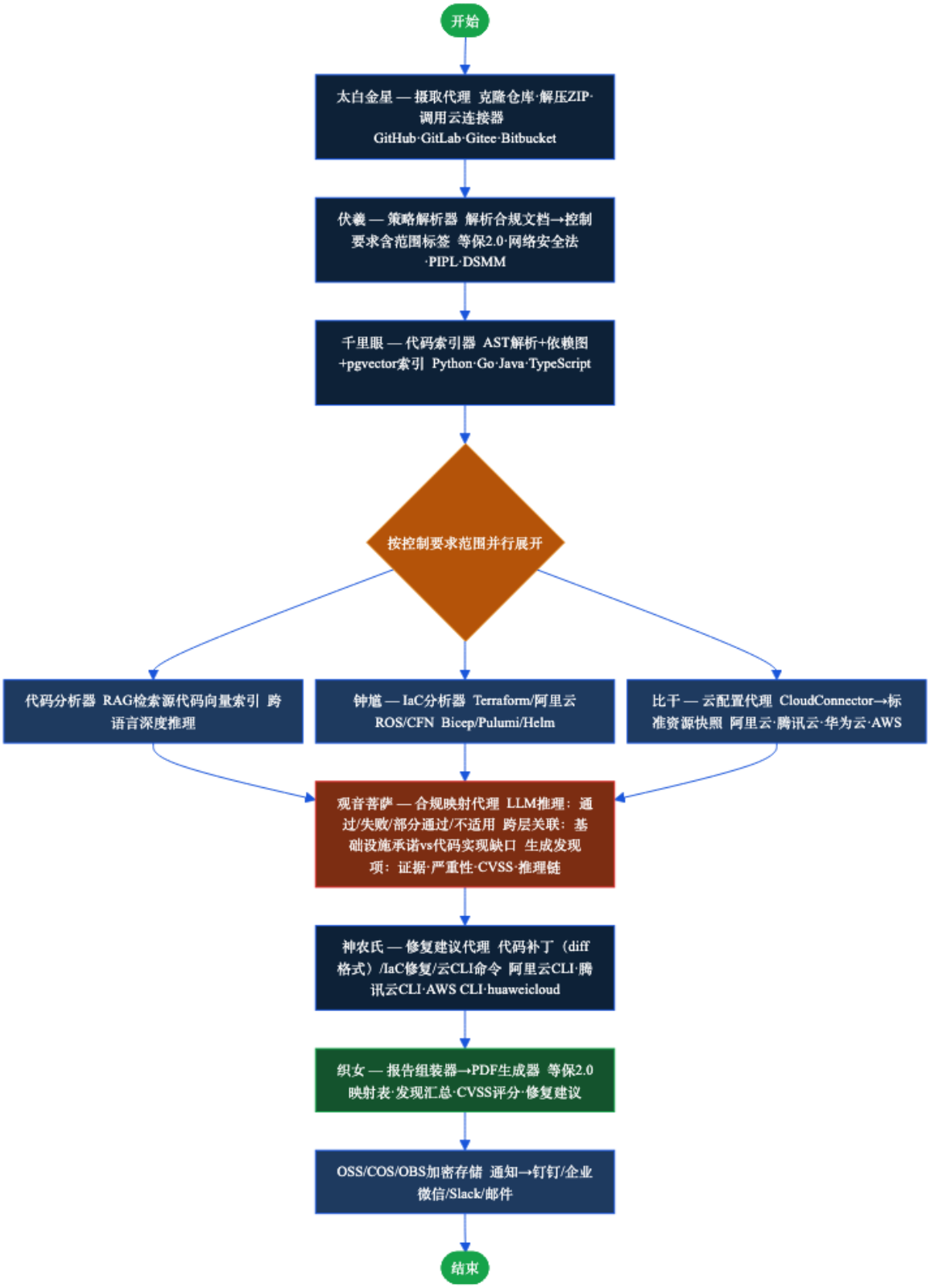

图2：九天神将作战流水线 — 按控制项并行展开 · 跨层关联分析

11.4 技术栈

层次	技术	多云适配说明
代理编排	LangGraph 0.2+	运行于任意 Kubernetes

层次	技术	多云适配说明
LLM 框架	LangChain 0.3+	支持 Bedrock、Azure OpenAI、阿里云通义、本地 Ollama
代码解析	tree-sitter、semgrep	语言原生
IaC 解析	python-hcl2、cfn-flip、阿里云 ROS SDK	厂商适配，统一接口
向量存储	pgvector（PostgreSQL）	RDS / PolarDB / 云数据库 / 裸机
LLM — 阿里云	通义千问（百炼 VPC 端点）	无公网出口
LLM — 腾讯云	混元大模型（私有 API）	无公网出口
LLM — 离线 / 信创	Ollama + Qwen3-Coder / DeepSeek-R1	零外部调用
对象存储	S3 兼容 API	阿里云 OSS / 腾讯云 COS / 华为云 OBS / MinIO
密钥管理	可插拔	阿里云 KMS / 腾讯云 SSM / HashiCorp Vault
认证	OIDC 兼容	阿里云 IDaaS / 腾讯 IDaaS / Keycloak
任务队列	可插拔	阿里云 MNS / 腾讯云 TDMQ / RabbitMQ
API 层	FastAPI + Uvicorn	容器化；多云无关
前端	Next.js 14 + TailwindCSS	静态构建；任意 CDN 或 K8s
基础设施	Terraform 模块	按厂商独立模块 + 共享核心层
报告生成	ReportLab + Jinja2	无云依赖

12. 开源大语言模型选择

12.1 为何国产大模型是核心战略选择

玄武合规引擎将国产开源大模型置于战略核心，原因有三：

合规性：中国《数据安全法》和《个人信息保护法》要求重要数据不出境。支持通义千问 Qwen3-Coder、DeepSeek-R1 在客户自有环境中部署，是满足数据主权要求的唯一路径。

性能：国产代码大模型已达到并超越境外模型在代码任务上的能力基准：

- Qwen3-Coder-Next-80B：SWE-Bench Verified 超 70%，超越 GPT-4o
- DeepSeek-R1 671B：多步推理达到前沿水平，代码理解深度无可比拟

政策加分：信创评审中优先采用国产技术，使用国产大模型是进入信创目录的必要条件之一。

12.2 推荐模型（按部署场景）

最高精度推理（大型 GPU 集群）

DeepSeek-R1（671B 参数，MoE 架构，MIT 许可）

- 最适用于：复杂跨文件漏洞推理、多步合规链分析
- 每次前向传播仅激活 37B 参数（MoE 效率）
- 硬件要求：4× NVIDIA A100 80GB 或同等设备

- 部署：vLLM 或 Ollama `deepseek-r1:671b`

Qwen3-Coder-480B-A35B（通义千问，Apache 2.0）

- SWE-Bench Verified 69.6%，超越 GPT-4o 和 Claude 3.7 Sonnet
- 上下文窗口：256K（可扩展至 1M），可摄取大型企业仓库单次完整分析
- 硬件要求：250GB 统一内存（4× H100 80GB）

标准私有云部署（单 GPU 节点）

Qwen3-Coder-Next-80B-A3B（通义千问，Apache 2.0）

- SWE-Bench Verified 超 70%，仅激活 3B 参数——性价比极高
- 硬件要求：46GB VRAM，可在单张 H100 80GB 上运行
- **推荐为大多数私有云部署的默认选型**

Qwen3-Coder-Plus（32B，Apache 2.0）

- 最适用于标准单 GPU 节点部署
- 上下文 128K，1× A100 80GB

资源受限 / 信创环境

DeepSeek Coder V2（16B / 236B，许可证商业友好）

- 支持 300+ 编程语言；适合多语言企业代码库
- 16B 版可在单张 A10G 24GB 运行

Mixtral 8x7B（Apache 2.0）

- 最低硬件门槛，适合现有 GPU 基础设施

12.3 模型选型指南

部署场景	推荐模型	理由
SaaS（云托管）	阿里云百炼通义千问 / Bedrock Claude	最高性能；无运维负担
阿里云私有云	通义千问百炼（VPC 端点）或 Qwen3-Coder-Next-80B	阿里云优先；开源备选
腾讯云私有云	混元大模型（私有 API）或 Qwen3-Coder-Plus	腾讯生态优先
华为云私有云	华为盘古大模型或 DeepSeek-R1 自托管	信创合规优先
离线 / 信创标准	Qwen3-Coder-Next-80B-A3B	70%+ SWE-Bench；46GB VRAM；Apache 2.0
离线最高精度	Qwen3-Coder-480B-A35B + DeepSeek-R1 671B	最强开源代码推理组合
CI/CD 快速扫描	Qwen3-Coder-Next-80B Q4 量化版	60 秒内完成；预提交检查级别

---

13. 三大国内云基础设施扫描覆盖

玄武合规引擎通过各云平台只读 API 凭证扫描实时运行配置，每个云平台均有专属适配器，将原生 API 数据规范化为统一的标准资源快照（ResourceSnapshot）后送入合规推理引擎。扫描过程不需要部署代理，不写入任何

数据，对生产环境零影响。

13.1 阿里云（Alibaba Cloud）扫描覆盖

通过只读 RAM 角色（RAM Role with STS Token）接入，扫描以下资源类型：

身份与访问管理（RAM）

- RAM 用户、角色、策略（内联和托管）——最小权限分析、通配符权限、权限提升路径
- 多因素认证（MFA）执行状态
- 服务控制策略（SCP）——组织级别防护栏

网络安全

- VPC 拓扑——子网分隔、流量日志、默认 VPC 使用
- 安全组——过度宽松的入站/出站规则（0.0.0.0/0 暴露）
- 网络 ACL、VPC 对等连接配置、PrivateLink 端点

存储与数据

- OSS 存储桶——公共访问屏蔽、ACL、存储桶策略、版本控制、服务端加密（SSE-OSS vs SSE-KMS）
- RDS 实例——加密、公开可访问性、备份保留、多可用区
- TableStore、KMS 密钥、证书管理

计算与容器

- ECS 实例——公网 IP 暴露、安全组、过期镜像
- ACK 集群——API Server 访问、加密、RBAC、节点安全策略
- 函数计算——函数策略、环境变量密钥、VPC 配置

安全服务配置

- 云安全中心——开启状态、基线检查规则覆盖、漏洞扫描配置
- ActionTrail 审计日志——多地域、日志完整性验证、OSS 投递配置
- 云盾 WAF——规则集、防护模式（观察/拦截）、IP 黑名单
- DDoS 防护——高防实例绑定、防护带宽配置
- 堡垒机（跳板机）——运维审计启用状态，等保三级强制要求

13.2 腾讯云（Tencent Cloud）扫描覆盖

通过只读子账号（CAM 策略：`ReadOnlyAccess`）接入，扫描以下资源类型：

访问管理（CAM）

- 子账号、协作者、角色——最小权限分析、通配符操作（*）检测、角色信任策略审查
- MFA 绑定状态——根账号及高权限子账号 MFA 强制执行检查
- API 密钥安全——密钥轮换状态、最后使用时间、过期策略
- 策略模拟器结果——权限实际生效路径分析

网络安全

- VPC 私有网络——子网划分、流量镜像、默认 VPC 隔离状态
- 安全组规则——0.0.0.0/0 入站暴露、端口范围过宽、出站限制缺失
- NAT 网关——EIP 绑定、出站路由策略

- 私有连接 / 专线接入（DC）——加密传输状态
- 网络访问控制（NACL）配置合规性

存储与数据

- 对象存储 COS——公有读写权限、存储桶策略、跨账号访问、版本控制、SSE-KMS 加密
- 数据库 TencentDB for MySQL / TDSQL-C——公网开放检测、数据加密、自动备份、多可用区
- Redis（云数据库 Redis）——认证密码、公网暴露、持久化配置
- 云加密机（CloudHSM）——密钥策略合规性

计算与容器

- 云服务器 CVM——公网 IP 暴露、安全组配置、镜像版本（过期内核）、启动模板安全
- 容器服务 TKE——API Server 公网访问控制、RBAC 策略、镜像仓库 TCR 扫描
- 云函数 SCF——触发器配置、环境变量明文密钥检测、VPC 接入状态
- 弹性伸缩（AS）——启动配置安全基线

安全服务配置

- 主机安全 CWP（云镜）——代理安装覆盖率、基线检查、漏洞修复状态
- 云审计 CloudAudit——操作日志投递 COS/CLS、日志完整性验证
- Web 应用防火墙 WAF——防护域名覆盖、规则模式
- 云防火墙 CFW——互联网边界防护、内网访问控制、IPS 功能状态
- 日志服务 CLS——日志组保留策略、加密配置

等保专项（腾讯云等保合规）

- 腾讯云等保合规评估服务状态（TCCC）
- 安全评级基线结果与差距分析

13.3 华为云（Huawei Cloud）扫描覆盖

通过只读 IAM Agency 接入（委托授权，仅 ReadAccess 权限），扫描以下资源类型：

统一身份认证（IAM）

- IAM 用户、用户组、委托——最小权限合规、通配符权限（*:*）检测
- 登录保护——MFA 验证策略、登录 IP 白名单
- IAM 委托（Agency）——跨账号信任范围、过度授权委托
- 访问密钥（AK/SK）——轮换周期、最后使用记录、过期策略
- 权限边界（Permission Boundary）配置有效性

网络安全

- 虚拟私有云（VPC）——子网规划、流量镜像、VPC 互联拓扑
- 安全组规则——0.0.0.0/0 入站、敏感端口暴露（22/3389/5432等）
- 云防火墙（CFW）——互联网边界防护状态、东西向流量控制
- 弹性公网 IP（EIP）——未绑定 EIP 清查、带宽策略
- 专属连接 DC——加密传输、链路冗余配置
- 虚拟专用网络（VPN）——加密算法合规性（禁止 MD5、DES）

存储与数据

- 对象存储 OBS——桶策略、公开访问控制、跨区域复制、SSE-KMS 加密（支持国密 SM4）
- 云数据库 RDS / GaussDB——公网访问禁用、SSL 加密、自动备份、实例加密
- 分布式缓存 DCS（Redis）——密码认证、网络隔离、持久化
- 数据仓库 DWS——认证方式、网络访问控制
- 文档数据库 DDS——认证状态、加密配置

计算与容器

- 弹性云服务器 ECS——弹性公网 IP 暴露、安全组规范性、镜像来源合法性
- 云容器引擎 CCE——API Server 访问策略、RBAC 配置、节点池安全组、镜像签名（支持国密证书）
- 函数工作流 FunctionGraph——触发器权限、环境变量安全、VPC 配置
- 裸金属服务器（BMS）——面向政府 / 金融的隔离部署合规性

安全服务配置

- 云审计服务 CTS——追踪器状态、日志转储 OBS、完整性校验
- 主机安全服务 HSS——代理部署覆盖率、勒索病毒防护、漏洞扫描周期
- Web 应用防火墙 WAF——防护规则集、CC 攻击防护策略
- 云堡垒机 CBH（Castle）——运维审计策略，等保三级合规强制项
- 漏洞管理服务 VSS——周期扫描计划、高危漏洞修复 SLA
- 数据加密服务 DEW——密钥轮换策略、密钥访问审计（国密 SM2/SM3/SM4 全面支持）

信创 / 国密专项

- 国密算法合规性检测：SM2 非对称加密、SM3 哈希、SM4 对称加密全链路覆盖
- 等保三级特殊要求：云堡垒机覆盖率 100%、审计日志保留 6 个月以上、数据库审计开启

13.4 等保 2.0 三云统一合规映射示例

等保 2.0 控制要求	阿里云检查项	腾讯云检查项	华为云检查项
二级 8.1.3 访问控制	RAM 无通配符；最小权限	CAM 无 * 权限；MFA 已开启	IAM 无 *:*；委托范围最小
三级 8.1.4 安全审计	ActionTrail 多地域；OSS 投递	CloudAudit 启用；CLS 保留 6 月	CTS 追踪器；OBS 转储；完整性验证
三级 8.1.5 入侵防范	安全组无 0.0.0.0/0；安全中心开启	CWP 代理覆盖；CFW 边界防护	HSS 全覆盖；CFW 已启用
三级 8.2.3 数据完整性	KMS 加密；密钥轮换	SSE-KMS；CloudHSM 策略	DEW/SM4 加密；密钥审计日志
三级 8.2.4 数据保密性	RDS/OSS 公网禁用；静态加密	TencentDB 无公网；COS SSE-KMS	GaussDB/OBS 加密；EIP 未绑定清查
三级 8.1.6 运维审计	堡垒机接入	—	CBH 云堡垒机覆盖率 100%（强制）
等保 AI 系统专项	函数计算权限；ACK RBAC	SCF 触发器权限；TKE 镜像签名	FunctionGraph VPC；CCE 镜像签名（国密）
国密算法要求（信创）	部分支持	部分支持	SM2/SM3/SM4 全链路（强制项）

13.5 跨层关联——玄武的独特洞察

跨层关联是玄武合规引擎最强大的能力——发现基础设施承诺与应用代码实现之间的断层。以下为三云真实场景示例：

阿里云场景

- OSS 服务端加密已启用（基础设施通过）→ 应用代码将解密后的明文直接写入日志（代码失败）→ 加密被应用层绕过，等保 8.2.4 失败
- RAM 角色已实施最小权限（IAM 通过）→ 函数计算代码在运行时动态假定更宽泛的角色（代码失败）→ 运行时权限提升，等保 8.1.3 失败
- ActionTrail 已启用（配置通过）→ 应用全局捕获异常并静默处理，无任何日志输出（代码失败）→ 威胁检测被应用层致盲，等保 8.1.4 失败

腾讯云场景

- TencentDB SSL 已强制（配置通过）→ 应用 JDBC 连接字符串设置 `useSSL=false`（代码失败）→ 传输中加密在代码层被禁用
- CAM 策略已限制 COS 写入（IAM 通过）→ 应用通过临时密钥绕过 CAM 策略直接写入（代码失败）→ 临时凭证滥用，数据泄露风险
- WAF 已开启（配置通过）→ 应用代码未对用户输入做 SQL 参数化处理（代码失败）→ SQL 注入风险在应用层存在，WAF 旁路可利用

华为云场景

- OBS 已配置 SM4 加密（配置通过）→ 应用代码使用明文 AK/SK 硬编码访问 OBS（代码失败）→ 密钥暴露风险，国密加密形同虚设
- CCE 已配置镜像签名验证（配置通过）→ CI/CD 脚本跳过签名验证标志（IaC 失败）→ 供应链安全漏洞，信创等保强制要求违反
- CBH 堡垒机已部署（配置通过）→ 应用运维代码包含直连数据库的后门连接字符串（代码失败）→ 堡垒机审计被绕过，等保 8.1.6 审计失效

---

14. 多云架构与路线图

14.1 服务商抽象架构

所有云厂商特定集成均封装于 `CloudProvider` 接口之后，暴露统一 API，无论底层厂商如何。所有资源数据标准化为标准资源快照（canonical ResourceSnapshot）后方可进入合规推理管线。

新增云厂商仅需实现接口适配器，零改动代理逻辑。

14.2 Terraform 模块库

```
deepguard-terraform/
■■■ modules/
■ ■■■ core/ ■■■■K8s ■■■Helm■■■■■■
■ ■■■ aws/ EKS■RDS■S3■Bedrock■Cognito
■ ■■■ aliyun/ ACK■PolarDB■OSS■■■ LLM■IDaaS
■ ■■■ tencent/ TKE■■■■■■COS■■■■■■ IDaaS
■ ■■■ huawei/ CCE■GaussDB■OBS■■■ LLM■■■ IAM
■ ■■■ azure/ AKS■Azure DB■Blob■Azure OpenAI■Entra ID
■ ■■■ gcp/ GKE■Cloud SQL■GCS■Vertex AI■Cloud IAP
■ ■■■ onprem/ ■■ K8s■MinIO■Vault■Keycloak■Ollama
```

```
■■■ examples/
■■■ aliyun-single-account/
■■■ aliyun-multi-account/
■■■ tencent-enterprise/
■■■ huawei-enterprise/
■■■ aws-enterprise/
■■■ multi-cloud-hub/
■■■ airgapped-datacenter/
```

14.3 多云扩展路线

阶段	云平台	预计时间	扫描覆盖
第 1 – 3 阶段	AWS + 阿里云	第 1 – 20 周	IAM、网络、存储、计算、安全服务
第 4 阶段	腾讯云 + 华为云	第 7 – 12 个月	CAM、CVM、COS、TKE；IAM、VPC、OBS、CCE
第 5 阶段	Azure + GCP	第 12 – 24 个月	Entra ID、VNet、RBAC；Cloud IAM、GCS、GKE
第 6 阶段	离线 / 信创 / VMware	第 24 – 36 个月	vSphere、OpenStack、裸机 K8s

15. 支持的合规框架

15.1 中国核心法规框架

框架	版本	扫描范围
网络安全等级保护 2.0（等保）	GB/T 22239-2019	代码 + 云配置；一/二/三/四级
《网络安全法》技术要求	2017	数据处理合规、访问控制、日志审计
《数据安全法》数据分类分级	2021	数据处理活动合规、跨境评估要求
《个人信息保护法》	2021	个人信息处理合规、最小必要原则
《生成式 AI 服务管理暂行办法》	2023	AI 系统安全评估要求、数据标注规范
金融行业信息技术风险管理指引	中国人民银行	金融科技系统安全要求
银行业金融机构信息科技风险管理指引	银保监会	银行信息系统合规

15.2 大中华区及国际框架

框架	适用范围
MAS TRM	新加坡金融机构
香港《网络安全条例》	香港关键基础设施运营者
PDPA（新加坡）	个人数据保护
ISO/IEC 27001:2022	国际信息安全管理
ISO/IEC 42001:2023	AI 管理体系

框架	适用范围
OWASP Top 10 / ASVS	Web 应用安全
OWASP LLM Top 10（2025）	大模型集成应用安全
PCI-DSS v4.0	支付卡数据安全
NIST AI RMF 1.0	AI 风险管理（美国市场扩张适用）
EU AI Act	欧盟高风险 AI 系统（欧洲客户适用）

15.3 自定义策略支持

企业可上传 PDF、YAML 或结构化 JSON 格式的自有安全策略、行业指南或监管函件。伏羲（策略解析器）将文档分解为可验证的原子控制要求，标注范围标签（代码/IaC/云配置/全部），并映射至统一分析管线。

16. 报告输出结构

每份玄武合规报告包含：

封面 — 企业名称、仓库/账户、扫描框架、扫描日期、报告密级、使用的 LLM 模型

执行摘要 — 三层统一合规得分（代码/IaC/云配置）；风险态势评级；前 5 项关键发现；Mythos 时代漏洞面评估；即时整改要求

合规态势仪表板 — 所有控制域与所有扫描层的可视化热力图

跨层关联洞察 — 代码缺口与基础设施缺口相互叠加放大风险的发现

发现清单 — 完整表格：控制要求编号、标题、严重性、状态、受影响资产（文件:行号 或 资源 ARN/ID）、CVSS 评分

详细发现 — 每项发现：策略原文、证据（注释代码或资源配置）、LLM 推理链、严重性评级依据

修复手册 — 按优先级排序：代码补丁（diff）、IaC 修复（Terraform/ROS/CFN）、CLI 命令、预估工作量、修复责任人

基础设施配置摘要 — 每个云厂商：资源清单、类型覆盖率、态势得分

方法论与局限性 — 分析方法、工具版本、LLM 模型及版本、置信度指标、已知局限

附录 A：策略-控制映射 — 框架要求 → 发现 → 证据 → 修复可追溯矩阵

附录 B：等保测评证据包 — 等保 2.0 格式化输出，可直接提交给测评机构

附录 C：扫描配置 — 仓库提交哈希、云账户 ID、框架版本、扫描参数

17. 建设路线图

第 1 阶段——MVP：代码 + 阿里云基础设施（第 1–8 周）

- GitHub、GitLab、Gitee 摄取 + ZIP 上传；Python 和 TypeScript 优先
- OWASP Top 10、等保 2.0 二/三级核心控制项
- 阿里云基础设施扫描：RAM、OSS、ECS、RDS、ActionTrail、安全组、VPC、ACK
- AWS 基础设施扫描（新加坡设计合作伙伴同步交付）
- 跨层关联（代码 + 云配置）统一报告

- PDF 报告含发现、证据、跨层洞察；等保测评证据包输出
- Terraform 阿里云 + AWS 部署模板（单租户 VPC）
- 开源 LLM 支持：Qwen3-Coder-Plus 32B via Ollama（第一天起支持离线）

第 2 阶段——完整代码 + 腾讯云 + 华为云（第 8–20 周）

- 多语言 AST：Java、Go、C#、PHP
- 腾讯云基础设施扫描：CAM、CVM、COS、TKE、SCF、CWP、WAF、CloudAudit
- 华为云基础设施扫描：IAM、VPC、OBS、CCE、GaussDB、DEW（国密 SM4）、CBH、CTS、HSS
- 全量等保 2.0 二/三/四级控制项覆盖（阿里云 + 腾讯云 + 华为云统一映射）
- ISO 42001、《生成式 AI 管理办法》、OWASP LLM Top 10
- IaC 扫描：Terraform（alicloud / tencentcloud / huaweicloud Provider）、阿里云 ROS、华为云 RFS
- 自定义策略摄入：PDF 和 YAML
- CI/CD SDK：GitHub Actions、GitLab CI、Gitee Go、CODING
- LangSmith 评测套件（含等保 2.0 中文框架专项基准）
- 阿里云市场 + 腾讯云市场 + 华为云市场同步上架；SAML/OIDC SSO

第 3 阶段——企业加固 + 信创认定（第 20–36 周）

- 全离线模式（完整开源技术栈）
- 多区域 SaaS（新加坡 ap-southeast-1、香港 ap-east-1）
- RBAC 含审批工作流；修复 PR 自动生成
- 等保测评证据包标准化输出（可直接提交全国 200+ 等保测评机构）
- 信创认定申请：信息技术应用创新工作委员会软件目录
- 国密算法全链路：SM2/SM3/SM4 支持（华为云信创强制要求）
- 华为 Atlas NPU 推理加速支持（盘古大模型 + Qwen3-Coder）
- SOC 2 Type II 认证（SaaS 平台）
- Glasswing 漏洞类别检测模块（2026 年 7 月后更新）

第 4 阶段——大中华区全覆盖（第 7–12 个月）

- 香港云配置扫描（阿里云香港、腾讯云香港、AWS 香港区域）
- 香港金管局 ORMS + 证监会科技风险 + 香港《网络安全条例》框架
- 台湾金管会资安要求框架
- 中国大陆通过合作伙伴渠道（等保测评机构联合方案）扩展
- Azure 私有云部署（面向跨国企业 Azure 环境）

第 5 阶段——Azure + GCP（第 12–24 个月）

- Azure 云配置扫描；AKS 部署
- GCP 云配置扫描；GKE 部署
- 欧洲/美国市场进入支持

第 6 阶段——离线 / 信创数据中心（第 24–36 个月）

- 裸机 GPU 自托管 LLM（DeepSeek-R1 / Qwen3-Coder）

- MinIO + HashiCorp Vault + Keycloak 全开源栈
- OpenShift、Rancher、VMware vSphere 适配器
- 信创国密算法（SM2/SM3/SM4）支持
- FIPS 140-3 / 国密算法合规

18. 结论与投资论据

致投资人的一封信

Anthropic 将他们最强大的模型命名为 Mythos——希腊神话中揭示世界隐藏真相的原始叙事。这个名字并非偶然：这些漏洞不是新危险，而是原始的——自软件诞生之初便埋入其中，沉睡数十年，只待足够强大的 AI 将其唤醒。

中国神话以不同的语言讲述了相同的智慧。玄武在自我净化的苦修之后，成为北方最强的守护神——他的防护不来自蛮力，而来自深度洞察与结构性约束。比干以七窍玲珑心洞穿欺骗，以生命为代价说出真相。钟馗专门揭露以合法面目潜伏的鬼魅。观音以无上智慧而非规则作出裁断。

玄武合规引擎就是这支神将团队的现代实现——为后 Mythos 时代而生，为数据主权要求而生，为中国监管体系而生。

五力共振的投资机会

以下五股力量在此时此刻同时收敛，创造了一个窗口期有限、先发优势决定性的机会：

Mythos 永久改变了威胁模型：规则匹配型 SAST 已被证明根本不足。LLM 推理是要求，不是差异化因素。玄武已经实现。

数据主权是中国市场的硬红线：任何需要将企业代码发送至境外 API 的工具，在中国合法合规市场都没有未来。私有化部署是玄武的永久结构性护城河。

国产大模型弥合了能力差距：Qwen3-Coder-Next-80B（SWE-Bench 超 70%）和 DeepSeek-R1（多步推理前沿水平）已使境外大模型不再是性能优势。纯国产技术栈成为可能。

监管是确定性非自由裁量支出：等保 2.0 年度强制测评、《网络安全法》百万级罚款、《生成式 AI 管理办法》安全评估要求——这些不是预算项，是法律义务。

没有竞争对手覆盖这一交叉点：代码扫描 + 多云配置 + LLM 推理 + AI 治理框架 + 国产大模型 + 等保 2.0 全覆盖 + 私有化部署——这一能力组合在全球范围内，目前只有玄武合规引擎。

投资回报摘要

所有金额以新加坡元（SGD）计，括号内为参考人民币。

指标	数据
总目标市场（TAM）	约 800 亿美元（2024）→ 约 2,400 亿美元（2030），Mythos 后加速
可服务市场（SAM）	约 80 – 100 亿美元（2027年）
第 5 年 ARR 目标	SGD 2,738 万（约人民币 1.45 亿）
第 5 年退出估值	SGD 2.7 亿—4 亿（约人民币 14 – 21 亿），10 – 15× ARR

指标	数据
战略收购方向	奇安信、华为云、腾讯安全、深信服；或 CrowdStrike、Wiz、Snyk
资本市场退出	港交所（科技股）或科创板（A 股上市）
天使轮需求	SGD 160 万（约人民币 848 万）
A 轮触发条件	ARR 超 SGD 200 万（预期第 18 个月）
规模化毛利率	85 – 87%
可用新加坡政府资助	MAS FSTI 最高 SGD 100 万；EDG 最高 70% 合格成本

窗口现在开着。 等保框架已生效，Mythos 威胁已实际存在，监管截止日期已设定，多云架构已成为默认选择，国产大模型已到达实用水平，大中华区企业市场正急迫寻找一个目前尚不存在的高质量解决方案。玄武就是那个答案。

"玄武北守，德配天地，威镇四方。" —— 《太上说玄天大圣真武本传神咒妙经》

文件密级：机密 — 商业计划书 v1.0

仅供签署保密协议的天使投资人参阅

联系：DeepGuard 产品团队 | support@hellodr.sg

---

19. 参考文献

Anthropic.（2026年4月）. *Claude Mythos Preview*. https://red.anthropic.com/2026/mythos-preview/

Anthropic.（2026年4月）. *Project Glasswing: Securing critical software for the AI era*. https://www.anthropic.com/glasswing

中国信息通信研究院.（2024年）.《中国网络安全产业白皮书（2024年）》.

工业和信息化部.（2024年）.《2023年中国网络安全产业统计》.

公安部.（2019年）.《信息安全技术 网络安全等级保护基本要求》GB/T 22239-2019.

全国人民代表大会.（2017年）.《中华人民共和国网络安全法》.

全国人民代表大会.（2021年）.《中华人民共和国数据安全法》.

全国人民代表大会.（2021年）.《中华人民共和国个人信息保护法》.

国家互联网信息办公室.（2023年）.《生成式人工智能服务管理暂行办法》.

Fortune.（2026年4月14日）. *Anthropic's Mythos finds software flaws faster than companies can fix them*. https://fortune.com/2026/04/14/

CNBC.（2026年4月14日）. *Jamie Dimon says Anthropic's Mythos reveals 'a lot more vulnerabilities' for cyberattacks*. https://www.cnbc.com/2026/04/14/

Cloud Security Alliance.（2026年）. *The 'AI Vulnerability Storm': A CISO's Playbook for the Mythos Era*. https://labs.cloudsecurityalliance.org/mythos-ciso/

IANS Research.（2026年4月13日）. *Anthropic's 'Project Glasswing' Exposes the Next Challenge for Vulnerability Management*.

DarkReading.（2026年）. *Report: CISOs Should Prepare for Post-Mythos Exploit Storm*.

Qwen Team, Alibaba Cloud.（2026年）. *Qwen3-Coder Technical Report*. https://arxiv.org/html/2409.12186v3

DeepSeek.（2025年）. *DeepSeek-R1: Incentivizing Reasoning Capability via Reinforcement Learning*.

Grand View Research.（2023年）. *Application Security Testing Market Size Report, 2030*.

MarketsandMarkets.（2023年）. *Cloud Security Posture Management (CSPM) Market — Global Forecast to 2028*.

IDC.（2024年）. *Worldwide AI Governance and Responsible AI Software Forecast, 2025 – 2030*.

Flexera.（2024年）. *State of the Cloud Report 2024*. https://info.flexera.com/CM-REPORT-State-of-the-Cloud

OWASP Foundation.（2025年）. *OWASP Top 10 for Large Language Model Applications v2025*. https://owasp.org/www-project-top-10-for-large-language-model-applications/

ISO/IEC.（2023年）. *ISO/IEC 42001:2023 — Artificial intelligence — Management system*.

货币管理局（新加坡）.（2021年）. *Technology Risk Management Guidelines*.

Center for Internet Security.（2023年）. *CIS AWS Foundations Benchmark v3.0.0*.

Schneier on Security.（2026年4月）. *On Anthropic's Mythos Preview and Project Glasswing*.

VentureBeat.（2026年）. *Mythos autonomously exploited vulnerabilities that survived 27 years of human review*.

SiliconFlow.（2026年）. *The Best Open Source LLM for Cybersecurity & Threat Analysis in 2026*.

奇安信.（2025年）.《中国软件供应链安全分析报告》.

工业和信息化部.（2023年）.《网络安全产业高质量发展三年行动计划（2021-2023年）》.

科技部.（2023年）.《国家新一代人工智能标准体系建设指南》.